By TOUCH DEN · November 11, 2026

Security Controls and Defense in Depth

Video 1 · Kinds of Control

Security Fundamentals · Section 8

In this video, you will learn:

- What a security control is
- Control types: preventive, detective, corrective
- Control categories: technical, administrative, physical

What a control is

A security control is any measure you put in place to reduce risk.

- *A password, a backup, a locked door, a training session, an antivirus, a log, a "two people must approve" rule, all controls.*
- *Controls are how **risk reduction** (lesson 3) actually happens.*

The art is choosing enough controls to bring risk to an acceptable level, without overspending or wrecking usability.

*We classify them two ways: by what they **do**, and by what they **are**.*

Control types: by function

Type	When	What it does	Examples
Preventive	Before	Stops it happening	MFA, locks, firewalls, training
Detective	During/after	Notices it happened	Logs, alarms, CCTV, monitoring
Corrective	After	Fixes and restores	Backups, patching, response plan

You need **all three**: prevention leaks, so you must detect; detection is useless if you can't recover. **Stop it, spot it, fix it.**

Control categories: by nature

Category	What it is	Examples
Technical	Built into technology	Encryption, firewalls, MFA, logging
Administrative	Rules, process, people	Policy, training, access reviews
Physical	Real-world things	Locks, doors, cameras, a safe

Security is not only technology. The lesson-1 ransomware beat all the tech because of a missing administrative control: training.

Recap: kinds of control

- *A control is any measure that reduces risk.*
- *Types: **preventive, detective, corrective**, you need all three.*
- *Categories: **technical, administrative, physical**, security isn't only tech.*
- *Each control has both a type and a category (a backup = corrective + technical).*

***Next video:** stacking controls into defense in depth.*

By TOUCH DEN · November 11, 2026

Security Controls and Defense in Depth

Video 2 · Defense in Depth, and Its Limits

Security Fundamentals · Section 8

In this video, you will learn:

- Defense in depth, properly
- A worked example of layered defense
- Where controls fail, and security vs. usability

Defense in depth, properly

Multiple layers of controls, so if one fails, others still protect the asset. *The "castle": moat, walls, locked keep.*

Why: *every single control can fail, a password is phished, a patch is missed, a firewall misconfigured. Depend on one, and the day it fails you're fully exposed.*

Good layering mixes ***types*** *(prevent, detect, correct) and* ***categories*** *(technical, admin, physical).*

Recall the attack lifecycle: the attacker must win every stage; ***you only have to break the chain once.***

Worked example: a customer database

Layer	Control	Type
1	Phishing training	Preventive
2	Email filtering	Preventive
3	MFA on all accounts	Preventive
4	Least privilege	Preventive
5	Database encrypted	Preventive
6	Alerts on large exports	Detective
7	Offline nightly backups	Corrective
8	Incident response plan	Corrective

Phish beats layer 1? MFA stops them. In anyway? Least privilege limits it; the export alert catches it. Worst case? Backups and the plan recover.

Where controls fail

- ***Misconfiguration:*** *present but set up wrong (an "open" firewall, an untested backup). Very common.*
- ***Human bypass:*** *people route around annoying controls, propped doors, shared passwords.*
- ***Decay:*** *patches lapse, reviews stop, a backup drive dies.*
- ***Unknown weaknesses:*** *a brand-new attack (zero-day).*

Two habits: *test your controls (an untested backup is a hope), and layer them, because any one can fail silently.*

Recap: defense in depth

- ***Defense in depth:*** *many layers, mixing types and categories, so one failure isn't full exposure.*
- *Controls fail by misconfiguration, bypass, decay, and the unknown, so test and layer them.*
- *Aim for* ***appropriate, usable*** *security, not maximum; over-tight controls get routed around.*

Next lesson: *ethics, the law, and permission to test.*